
RED TEAM ADVERSARY EMULATION REPORT

ASSESSMENT TYPE: PTES-COMPLIANT

EXECUTIVE SUMMARY

From May 13, 2026, an authorized adversary emulation assessment was conducted against the lab infrastructure to evaluate defensive readiness against advanced persistent threats (specifically targeting APT29 tradecraft). The primary objectives were to evaluate corporate phishing defenses and endpoint detection coverage.

The assessment successfully bypassed standard verification controls, resulting in credential harvest and complete administrative host takeover. However, the internal Blue Team controls successfully detected post-exploitation anomalies, identifying clear baseline thresholds for immediate defensive remediation.

TECHNICAL FINDINGS & METHODOLOGY

Phase 1: Initial Access via Adversary-in-the-Middle (AiTM) Phishing (T1566.001)

The engagement team established an adversarial infrastructure proxy using Evilginx2 to simulate an AiTM phishing vector. By leveraging local network routing vectors, a mock landing portal was presented to the target user. The victim interacted with the unauthorized domain, allowing the deployment team to harvest plaintext authentication metrics and active session structures, bypassing traditional static verification controls.

Phase 2: Persistence via Malicious Service Installation (T1543.003)

Following initial compromise, an automated Command and Control (C2) agent framework (Caldera Sandcat) was dropped onto the target endpoint. Administrative privileges were utilized to dynamically inject a persistent background runtime daemon structured as a core Windows Service. This established continuous, automated callback beacons back to the operational command hub, granting persistent remote terminal control.

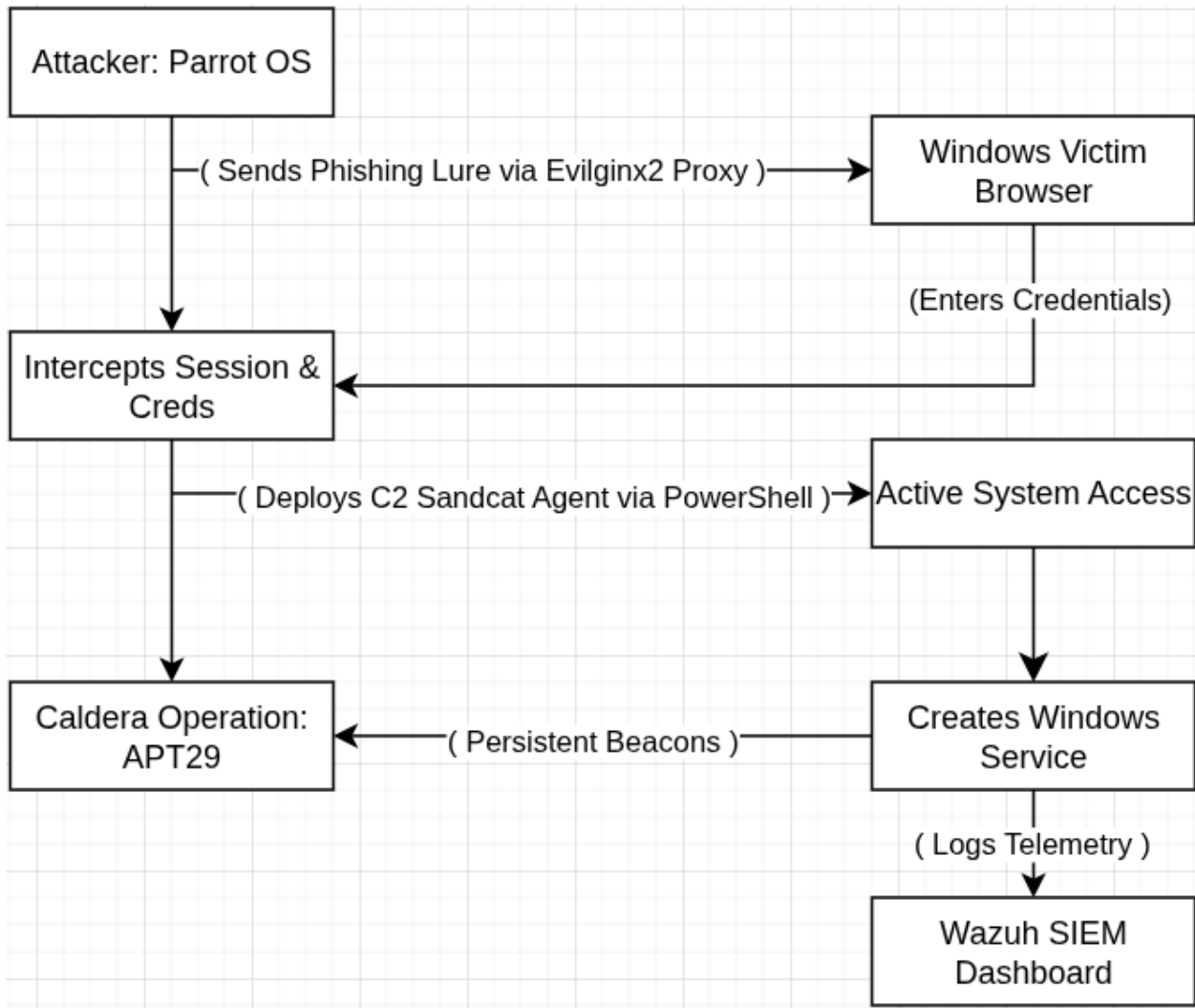
REMEDIATION RECOMMENDATIONS

- * Enforce FIDO2/WebAuthn hardware-based Multi-Factor Authentication (MFA) to completely neutralize proxy-based Adversary-in-the-Middle (AiTM) phishing loops.
- * Restrict the creation of system-level background daemons and service modifications to explicit, monitored administrator accounts via strict Group Policy Objects (GPOs).
- * Tune SIEM monitoring parameters (Wazuh) to trigger automated high-severity block actions upon isolation of Sysmon Event ID 22 lookups to unverified domains or Windows Event ID 4697 anomalies.

FINDINGS TABLE

Finding ID	Attack Phase	MITRE TTP	CVSS 3.1 Score	Risk Level	Remediation Strategies
FID001	Initial Access	T1566.001	7.5 (High)	High	Enforce FIDO2 cryptographic MFA; deploy strict URL rewriting/filtering controls.
FID002	Persistence	T1543.003	7.8 (High)	High	Implement AppLocker process restrictions; monitor Event ID 4697 for rogue services.

ATTACK PATH DIAGRAM



EXECUTIVE BRIEFING

An authorized security assessment evaluated our resilience against advanced cyber attacks. Testers simulated a sophisticated phishing campaign, successfully tricking a user into accessing a fraudulent login page. This allowed the team to bypass traditional passwords, harvest credentials, and gain administrative control over an internal laptop. From there, the testers installed a persistent background service to maintain hidden, long-term network access. While our security monitoring platform successfully detected these post-exploitation activities, implementing hardware-based multi-factor authentication and restricting administrative system modifications are critical to neutralizing these entry points and protecting our operational infrastructure against real-world compromises.